

요약

보안을 개인의 숙련이 아니라 **조직이 굴릴 수 있는 체계**로 만드는 일을 해왔습니다. 트렌비에서 **CISO · CPO로 보안 조직을 직접 리딩**하며 정보보호위원회를 운영했고, 개인정보 유출 사고를 초기대응부터 **개인정보보호위원회 · KISA 현장점검까지 지휘해 과징금 없이 종결**했습니다. 같은 기간 클라우드 보안 프레임워크를 재설계해 3년여 보안 무사고 운영을 유지했습니다.

규제는 우회 대상이 아니라 설계 변수라고 봅니다. ISMS-P 인증심사는 LG CNS 플랫폼사업·트렌비·무신사 세 조직에서 대응했고, 그중 LG 건은 별도 보안 장비 없이 AWS 관리형 서비스만으로 요건을 충족하는 프레임워크를 설계해 심사 승인을 받았습니다. 금융권 컨테이너 도입 때는 **금융감독원에 제출할 소명자료**를 직접 작성했고, 방송통신위원회 중재에서는 중립 데이터센터 지위를 확보했습니다. 네이버에서는 **공정거래위원회 조사와 고용노동부 현장점검**에 실무로 대응했습니다. **항목을 구조화하고, 각 항목에 사실관계와 근거를 매핑하고, 설명 가능한 기록을 남긴다** — 이 한 가지 방법론으로 여섯 곳의 규제기관을 대응했습니다.

지금무신사에서 전자 장애프레임워크의 Owner로 **사고 대응 체계와 비상대응훈련 프로그램**을 설계·운영하며, 이커머스·플랫폼 환경의 보안성 검토와 ISMS-P 대응을 함께 맡고 있습니다.

과징금 0원

개인정보 유출 사고 — 규제기관 현장 점검까지 지휘

3개 조직

ISMS-P 인증심사 대응 (LG CNS · 트렌비 · 무신사)

규제기관 6곳

개인정보위 · KISA · 금융원
방통위 · 공정위 · 고용노동부

3년여

보안 무사고 운영 (트렌비 CISO)

직무 관련 핵심 역량

정보보호관리체계 구축·운영과 인증심사 대응

ISMS-P · 위험 분석·평가

심사 대응의 핵심은 기술이 아니라 번역입니다. 같은 통제 목적을 다른 수단으로 달성했다는 것을, 심사 기준의 언어로 설명할 수 있어야 합니다.

- ISMS-P 인증심사 대응 — 3개 조직 LG CNS 플랫폼사업(스타랩스) · 트렌비 · 무신사
- Layer × Component 매트릭스 — 계층(Cloud · 서버 · DB · 네트워크 · 애플리케이션) × 통제영역(접근제어 · 인증 · 권한 · 암호화 · Logging / Monitoring · 취약점 · Compliance)의 교차점마다 요구사항을 정의하고 구현 수단을 배치. 각 통제가 **관리형 서비스 · 자체 구현 · 3rd Party 중 무엇으로 충족되는지**를 근거와 함께 매핑해 심사에 대응
- 당시 관행이던 "클라우드에도 보안 장비를 엮는" 방식 대신 **별도 장비 없이 AWS 관리형 서비스만으로 요건을 충족하는 프레임워크를 설계해 심사 승인**, LG화학 · LG디스플레이 · LG CNS 운영 가이드선으로 확산
- 트렌비 — 위 프레임워크를 e-Commerce 환경에 맞춰 재설계, **갱신 심사 지적사항(로깅 정책 · 접근통제) 조치 완료**
- 심사용으로 만든 매트릭스가 평시 아키텍트 표준으로 쓰였습니다. 신규 서비스를 올릴 때 "이 계층의 이 통제는 무엇으로 하는가"가 이미 정의돼 있어 매번 처음부터 설계하지 않게 됐습니다

규제기관 대응 · 조사/현장점검 · 대외 보고

컴플라이언스 · 감독기관

조사와 점검은 기관이 달라도 구조가 같습니다 — 항목을 구조화하고, 각 항목에 사실관계와 근거를 매핑하고, 설명 가능한 기록을 남긴다. **여섯 곳의 규제기관을 같은 방식으로 대응**했습니다.

- 개인정보보호위원회 · KISA 현장점검** — 대응전략 프레임워크를 수립·이행하고 점검 전 과정을 지휘. 점검 항목을 구조화하고 각 항목에 대해 **무엇이 있었고 무엇을 했는지**를 근거와 함께 매핑하는 방식으로 대응
- 금융감독원 소명자료 작성·제공** 넥스클라우드 · 금융권 컨테이너 도입 — 금융보안 환경에서 컨테이너를 어떻게 통제할 수 있는지 규제기관에 설명하는 근거 문서를 작성. 기존 금융보안 통제 항목 하나하나에 대해 컨테이너 환경의 상용 통제가 무엇이고 왜 동등하거나 더 나은지를 입증
- 방송통신위원회 중재** — 네트워크 중립성 전략을 담당해 중재에서 승소, 중립 데이터센터 지위 확보와 **통신사 약관 개정**
- 전기통신사업법** — 기간통신사업자 면허 없이 가능한 DWDM 전송망 구축 방식을 설계해 법령 요건 충족
- 시정조치 이행보고 및 개선권고 이행** — 약 3년간 대외 보고 수행 트렌비 · CISO/CPO — 사고 대응 **1차년도에 시정조치 이행보고**를 완료하고, 이후 **지속 모니터링 체계로 개선권고 이행 보고**를 이어감. 일회성 소명이 아니라 **사고 이후 수년에 걸친 법정 보고 사이클을 책임자로서 끝까지 운영**한 경험
- 공정거래위원회 조사 대응** 네이버 · 부동산 매물확인 서비스 — 서비스 담당 PM으로 조사 대응 실무를 수행하고, 취급 중지 결정에 따른 서비스 정리와 후속 이행까지 담당
- 고용노동부 현장점검 대응** 네이버 · 도급 운영 형태 — 현장점검에 실무로 대응. 계약·작업지시·근태 기록 등 실제 운영 실태를 점검 항목에 맞춰 정리하고 소명
- Yahoo Korea — ASIA 보안협의체 구성원으로 정기·수시 점검 수행, **대만 HQ 보고 및 Asia Pacific 보안심사 이행**
- 조사 대응의 성패는 조사 시점의 대응력이 아니라 **평소에 남아 있는 기록**에서 갈립니다. 점검 항목에 대해 사후에 만들 수 있는 근거는 없습니다

- **개인정보보호책임자(CPO)** — 서비스 이용약관에 고지된 공식 선임 책임자 트렌비로서 개인정보 처리방침과 위탁 현황에 대한 대외 책임을 직접 부담
- **개인정보 유출 사고 대응 총괄** — 사고 발생 시점부터 규제기관 현장점검까지 지휘. 대응 매뉴얼 즉시 발동으로 고객 통지·응대와 KISA 신고 등 초기 대응을 시한 내 완료. **과징금 없이 과태료 270만 원으로 종결**
- **개인정보 처리위탁 계약 검토·수탁사 관리** — 수탁사 현황과 위탁 처리 절차를 정리하고, 위탁계약의 개인정보 보호조치·재위탁 제한·점검권 조항을 검토해 통제 요구사항을 계약과 정기 점검 체계에 반영
- **벤더·외주 계약 리스크 관리** — AWS EDP 계약, MSP 보상 합의, CDN 비용전략 합의 등 계약 구조 자체를 조정. **MSP 기술지원을 받지 않고 인프라를 자체 운영**하는 체제로 전환해 외부 사업자 의존성과 운영 통제권 문제를 구조적으로 해소
- **네이버** — 기간통신사업자(KT·LG U+·SKB) 회선 계약 전략 총괄, 대규모 인프라 이전 사업자 선정과 계약 조건 총괄
- 사고 대응에서 배운 것은 속도보다 기록이었습니다. 무엇을 언제 알았고 무엇을 했는지가 남아 있어야 현장점검에서 설명이 됩니다 — 이후 설계한 사고 대응 체계에 **기록 전담 역할과 타임라인 강제**를 넣은 이유입니다

보안 거버넌스 운영 · 정책 수립 · 팀 리딩

정보보호위원회 · 정책

- **정보보호위원회 운영** — CISO로서 보안 의사결정 협의체를 주관하고 경영진 대상 보안·개인정보 리스크 보고 체계 운영
- **보안 조직 직접 리딩** — 트렌비 CISO·CPO 겸 SRE Lead로 보안 실무 조직을 이끌며 정보보호·개인정보보호·플랫폼 신뢰성을 하나의 판단 체계로 운영
- **의사결정 구조의 이원화 설계** 무신사 — 사고 진행 중에는 IC 단일 지휘로 승인 게이트를 제거해 대응 속도를 확보하고, 정책·프로세스 결정은 **DACI로 Driver·Approver를 명문화**. 속도와 책임 소재를 구조로 분리
- **전사 정책·지침 문서 체계 수립** — 장애·사고 대응 SOP를 13개 영역과 부록 체계로 문서화하고 전사에 정착, 개정 이력 관리와 **최종 승인권자 역할** 수행
- 정책이 지켜지지 않는 이유는 대개 내용이 아니라 단어였습니다. "예외"나 "결함" 같은 말이 붙으면 사람들은 규정을 지키기보다 피합니다. 통과율을 올린 건 기준 완화가 아니라 표현 교체였습니다

보안성 검토 · 클라우드/인프라 보안 · 망분리

보안성 검토 · 망분리(VDI)

- **망분리(VDI) 통제 설계** — ISMS-P 프레임워크 내 편입 스타랩스 · LG CNS 플랫폼사업 — ISMS-P 심사 대응의 스크럼마스터로 보안 프레임워크와 가이드라인을 제시하면서 **망분리(VDI)를 통제 항목으로 포함**해 설계, 계열사 운영 가이드선으로 확산
- **망분리 재구현** — 장비에서 Identity로 트렌비 — 같은 요건을 **SDN·Okta 기반 ZTNA로 재구현**. 별도 장비 없이 Identity 식별만으로 충족해 운영 부담과 비용을 동시에 낮춤. 망분리를 **VDI 방식과 Identity 방식 양쪽으로 설계·운영**해본 경험이 있어, 환경과 인력 규모에 따라 어느 쪽이 맞는지 근거를 갖고 판단할 수 있습니다
- **운영 작업환경 자체를 클라우드 안으로 분리** 트렌비 · EKS 운영 — 로컬 단말에서는 운영 환경에 직접 접근할 수 없게 막고, **AWS Cloud9 기반 클라우드 개발·운영 스튜디오 안에서만 작업**하도록 구성. 운영 자격증명과 소스가 개인 단말에 남지 않고 작업 이력이 클라우드에 집중됩니다 — **VDI가 푸는 문제를 클라우드 네이티브 방식으로 해결**한 구성이자, EKS 운영 효율을 함께 얻은 선택이었습니다
- **인증·접근통제 단일화** — Okta 기반 SSO/SAML로 전사 애플리케이션 인증체계 통합, Teleport로 운영 접근 경로 통제, IAM 전면 재설계
- **AWS 환경 보안성 검토** — WAF 구축, 클라우드 리소스 Private 전환(80/443 외 차단), Multi VPC·Transit Gateway·Site-to-Site IPSec 구성, GuardDuty·CSPM/CWPP 기반 상시 점검
- **Landing Zone·거버넌스 기반 구축** LG 지주사 — AWS Organization·Landing Zone·Security VPC(UTM·WAF·접근제어) 설계, FWaaS로 인터넷-클라우드 구간 통제
- **실시간 보안 모니터링** — Flink 기반 실시간 WAF 모니터링, Imply 기반 클라우드 Audit 체계 구축

사고 대응 체계 · 비상대응훈련 · 취약점 점검

침해사고 · 모의훈련

- **전사 사고 대응 체계 Owner** 무신사 — 등급 체계(SEV 0~4), 역할 모델(지휘·조치·커뮤니케이션·기록), 6대 운영 원칙, 7단계 종료 게이트를 설계하고 원인분석(RCA) 확정의 최종 승인권자로 운영
- **비상대응훈련(모의훈련) 프로그램** — 설계부터 운영까지 주도 무신사 — 단계별 로드맵, **100점 루브릭 채점(70점 미만 재실시)**, LLM 이중 채점으로 채점자 편차를 줄여 훈련 품질을 정량화. Reliability 주도에서 각 조직 자체 주도로 이관하는 계획까지 설계·운영. **훈련을 일회성 행사가 아니라 통과 기준과 기록이 남는 정기 프로그램으로 만든 것이 핵심**
- **Chaos Engineering 상시화** 트렌비 · EKS 플랫폼 — **Instance Fail과 Availability Zone Fail은 실제 장애를 주입**해 검증하고, Region Fail은 Standby 복구 절차 점검까지 수행. 문서로만 존재하던 대비 체계를 **실제로 깨뜨려 확인하는 체계**로 전환해 **무중단 서비스와 연간 가용성 99.98% 목표**를 달성
- **취약점 점검 체계** — 소스코드 진단·모의해킹·인프라 및 클라우드 취약점 진단을 Layer × Component 매트릭스의 상시 점검 항목으로 편입
- **대외 보고 체계** — 격주 Incident Flash Report와 SLA 위반·Error Budget 추적을 경영 보고 라인에 연결

경력

무신사 Site Reliability Engineer · 전사 장애관리 Incident Owner

2025.01 - 현재

- 전사 사고·장애 대응 프레임워크(13개 영역 SOP) 설계·정착, RCA 확정 최종 Approver
- ISMS-P 인증심사 대응, 비상대응훈련 프로그램 설계·운영
- 무신사·29CM 전 서비스 SLO 수립 주도, Alert Gateway·인시던트 봇·훈련 채점에 LLM 적용

트렌비 정보보호최고책임자(CISO) · 개인정보보호책임자(CPO) 겸 SRE Lead 2021.06 – 2024.12

- **보안 조직 리딩, 정보보호위원회 운영**, 경영진 대상 보안·개인정보 리스크 보고. **서비스 이용약관에 고지된 공식 선임 CPO**
- 개인정보 유출 사고 대응 지휘 — 개인정보보호위원회·KISA 현장점검까지, **과징금 없이 종결**. 이후 약 **3년간 규제기관 수시보고 수행**
- 개인정보 처리위탁 계약 검토와 수탁사 점검 체계 운영
- Layer × Component 매트릭스 기반 클라우드 보안 프레임워크 재설계, Okta ZTNA 망분리, **3년여 보안 무사고**
- 개인정보 처리위탁 관리, 벤더 계약 구조 조정과 MSP 자체 운영 전환으로 제3자 의존성 해소
- EKS 플랫폼 재구축으로 가용성 99.98%, 월 인프라 비용 43.9% 절감(연 약 10억 원)

넥스클라우드 · OSC Korea Consulting Team Leader · Cloud Native Consultant 2020.02 – 2021.05

- 금융권 컨테이너 도입 — 금융감독원 소명자료 작성, 구축·운영·보안 3개 영역 통제 과제 도출과 역량 이관
- NIPA 5G MEC 국가 R&D 과제 PM — Multus·MetalLB로 Data/Management Plane을 분리한 멀티테넌시 설계
- Gremlin 기반 Chaos Engineering으로 현대자동차 Backend 장애 내성 검증

스타랩스 Cloud Architecture · Governance Strategy 컨설팅 2018.11 – 2020.01

- LG CNS 플랫폼사업 **ISMS-P 심사 대응 스크럼마스터** — 보안 프레임워크와 가이드라인 제시(**망분리 VDI 통제 포함**), **AWS 관리형 서비스만으로 ISMS-P 통과**, 3개 계열사 운영 가이드선 확산
- LG그룹 최초 인트라넷·Public Cloud 연결(MPLS·BGP·FWaaS), Landing Zone·Security VPC 구축

아이엔소프트 Private Cloud · CMP · DRaaS PO/PM 2016.05 – 2018.10

- 현대오토에버 Private Cloud PO/PM, 롯데정보통신 CMP·DRaaS 사업 설계, SK텔레콤 IT자산·구매 프로세스 혁신 PM

NAVER 데이터센터·클라우드 사업 PO · IT기획 · IT구매 · 인프라 PM 2007.04 – 2014.07

- 방송통신위원회 **중재로 중립 데이터센터 지위 확보**, 기간통신사업자 회선 계약 전략 총괄
- 공정거래위원회 **조사 대응**(부동산 매물확인 서비스 PM)과 **고용노동부 현장점검 대응** 실무 수행, 후속 중소기업 지원 펀드 투자 검토 참여
- 전사 인프라 변화관리 SPoC — 모든 변경을 단일 창구로 통제하고 ITSM 프로세스로 표준화, **서버 25,000대 보안 템플릿 일괄 배포**
- 춘천 데이터센터 연구과제부터 준공까지 약 5년, 보안장비 6종(IDS/IPS/DDoS) 포함 설비 조달 총괄
- Unix/Linux·Windows·Cisco/Juniper, L3 ACL 및 Server-side 보안 담당

Yahoo Korea Oracle DBA · 보안 (ASIA) 2006.04 – 2007.03

- ASIA 보안협의체 구성원 — 정기·수시 점검, 대만 HQ 보고, Asia Pacific 보안심사 이행
- 지도·검색·UCC 서비스 DB 구축·운영 (Oracle RAC, Data Guard)

NAVER 인프라 운영 PL 2002.12 – 2006.02

- 서버 가상화 도입, 한게임 DB·네트워크 및 목동·분당 IDC 이중화 구축
- **보안심사와 IT감사 결합 조치 이행**

기타

규제 · 인증	ISMS-P 인증심사 대응(3개 조직) · 개인정보보호법 사고 대응 및 개인정보보호위원회·KISA 현장점검 · 금융감독원 소명 · 공정거래위원회 조사 · 고용노동부 현장점검 · 방송통신위원회 중재 · 전기통신사업법 · 보안심사/IT감사 결합 조치
보안 기술	Okta(SSO·SAML·ZTNA) · 망분리 — VDI 통제 설계 · Identity(ZTNA) 구현 · AWS Cloud9 기반 운영환경 분리 · WAF · GuardDuty · CSPM/CWPP · Teleport · IAM 설계 · AWS Landing Zone/Security VPC · Flink 실시간 WAF 모니터링
거버넌스 도구	정보보호위원회 운영 · 규제기관 수시보고 체계 · Layer × Component 통제 매트릭스 · DACI · ITSM 변경관리 · SOP 체계와 승인 게이트 · 비상대응훈련 루브릭
플랫폼	AWS · EKS · GitOps(ArgoCD) · Istio · Terraform/Terragrunt · Datadog · Prometheus/Grafana/Loki · Jira · Confluence · PagerDuty
도메인	이커머스·플랫폼(무신사·29CM·트렌비) · 금융권 컨설팅 · 엔터프라이즈/그룹사 · 통신·데이터센터

학력

상지대학교 · 산업공학 학사 1997 – 2005